

Políticas y marco legal de Aether ERP

Lista de lanzamiento, documentos públicos y políticas internas de seguridad, incidentes, conservación y continuidad. Estado al 3 de octubre de 2026. No es asesoría legal: un abogado debe revisarlo antes del primer contrato.

Lista de lanzamiento: legal y operativa

Lo que hay que tener listo antes de ofrecer Aether a clientes, en orden de prioridad. Basada en una revisión del código y del estado real de Vercel y Neon el **3 de octubre de 2026**.

Leyenda: **[Tú]** lo hace el dueño en un panel u oficina · **[Abogado]** requiere revisión profesional · **[Código]** ya resuelto en el repositorio.

A. Bloqueantes: antes del primer cliente

Empresa y contratos

- [] **[Tú]** Operar a través de una sociedad (por ejemplo una SpA) y no como persona natural: separa tu patrimonio personal de las deudas y reclamos del negocio.
- [] **[Tú]** Inicio de actividades en el SII con un giro de desarrollo y venta de software, y emisión de tus propias facturas a los clientes.
- [] **[Tú]** Definir en Vercel AETHER_LEGAL_NAME, AETHER_LEGAL_RUT y AETHER_LEGAL_ADDRESS: los términos identifican al proveedor con ellas. **Hoy no existen en producción.**
- [] **[Abogado]** Revisar /aether/terminos, /aether/privacidad, /aether/encargado, /politica-privacidad y los documentos de esta carpeta. Preparar una cotización o contrato comercial modelo que remita a los términos.
- [] **[Tú]** Consultar en INAPI si la marca "Aether" está disponible en la clase de software y registrarla. Es un nombre común: si otra empresa la tiene registrada, conviene saberlo antes de invertir en ella.
- [x] **[Código]** Términos con tope de responsabilidad, exclusión de daños indirectos, indemnidad, suspensión por no pago, plazo de borrado al terminar, IA, eventos y tribunales.
- [x] **[Código]** Aceptación registrada de términos y privacidad al activar cada cuenta (versión y fecha).

Datos personales (Ley 19.628 y Ley 21.719, vigente desde el 1 de diciembre de 2026)

- [x] **[Código]** Aviso de privacidad en entradas, votos, cuotas, portal del auspiciador y encuesta (/aviso-privacidad).
- [x] **[Código]** Certificados médicos y documentos de candidatas en un bucket privado (requiere el paso siguiente).
- [] **[Tú]** Crear el bucket **privado** en Cloudflare R2 y las variables R2_* y R2_PRIVATE_BUCKET_NAME en Vercel. **Hoy producción no tiene R2 configurado:** todo sigue en Vercel Blob público.
- [] **[Tú]** Migrar al bucket privado los certificados médicos ya subidos (pedirlo: hay que escribir un script y probarlo en una rama de Neon).
- [] **[Tú]** **Borrar las 7 ramas de Neon** preview/*, vercel-dev y ensayo-categorias-auspicio: son copias completas de producción, con datos personales reales, creadas por la integración de Neon con Vercel. Después, configurar la integración para que las vistas previas no copien datos de producción.
- [] **[Tú]** Pasar Gemini a un plan de pago antes de procesar datos reales de clientes (en el plan gratuito, Google puede usar lo enviado para mejorar sus productos).
- [] **[Abogado]** Evaluación de impacto para el módulo de candidatas (datos sensibles de salud y de menores) y decidir si se nombra un delegado de protección de datos. Ambos son voluntarios, pero atenúan sanciones.
- [] **[Código, pendiente]** Al eliminar una empresa, borrar también sus archivos en R2/Blob (hoy es manual; ver conservación y respaldos).

Infraestructura

- [] [Tú] Neon: **pasar el proyecto** erp **del plan gratuito a Launch**. Hoy tiene restauración de solo 6 horas y un tope de 1 GB por rama.
- [] [Tú] Neon: marcar la rama `production` como **protegida** (hoy no lo está).
- [] [Tú] Dejar de usar la base de producción desde el `.env local`: crear una rama `desarrollo` y apuntar ahí.
- [] [Tú] Vercel Pro (uso comercial y 13 tareas programadas).
- [] [Tú] Verificación en dos pasos en Vercel, Neon, Cloudflare, GitHub y el proveedor de correo, y una **segunda persona** con acceso de administrador.

B. Primeras dos semanas

- [] [Tú] Conectar Cloudflare según `docs/security/cloudflare.md` y definir `CLOUDFLARE_ORIGIN_SECRET`, `NEXT_PUBLIC_TURNSTILE_SITE_KEY` y `TURNSTILE_SECRET_KEY` (**ninguna existe hoy en producción**). Después, el bloqueo de origen en el firewall de Vercel.
- [] [Tú] Crear una cuenta gratuita de Sentry y definir `SENTRY_DSN`.
- [] [Tú] Monitor externo de disponibilidad (UptimeRobot, Better Stack) con aviso al celular.
- [] [Tú] Eliminar de Vercel `TAVILY_API_KEY`: el código no la usa.
- [] [Tú] Confirmar que `ZAPSIGN_BASE_URL` apunta a producción (`https://api.zapsign.com.br`) y no al `sandbox`; si no, las firmas no tienen validez legal.
- [] [Tú] Primera prueba de restauración de Neon a una rama nueva.
- [] [Tú] Completar la tabla de contactos de emergencia en `respuesta-incidentes.md`.
- [x] [Código] Errores de producción corregidos: montos fuera de rango, aviso SSL que llenaba los registros y modelo de NVIDIA dado de baja.

C. Lo que cada cliente organizador debe saber (avisar al venderle)

Estas obligaciones son del **cliente**, no de Aether (términos, sección 6), pero si no las cumple el problema te salpica. Inclúyelas en el material de incorporación:

- Publicar las **bases del certamen**: requisitos, selección, jurado, premios y uso de la votación pagada (que no dependa del azar).
- Autorización del **representante legal** de cada candidata menor de edad y contrato de **uso de imagen**.
- Venta de entradas y votos a consumidores (Ley 19.496): precio total, condiciones de devolución y, si excluye el **derecho de retracto** de la compra a distancia, informarlo de forma clara antes del pago.
Confirmar con el abogado.
- Emitir los documentos tributarios de lo que vende (entradas, votos, cuotas).
- Completar en la plataforma el correo de contacto del certamen y, si es persona natural, revisar los datos que publica la política de privacidad.

D. Revisión periódica

Frecuencia	Qué
Semanal	Errores en Sentry/Vercel, tareas programadas ejecutadas, alertas de folios del SII.
Mensual	Costos, consultas lentas en Neon, <code>npm audit</code> , usuarios y claves sobrantes, exportación de respaldo por empresa.
Trimestral	Prueba de restauración, reglas del WAF, este documento.
Cada cambio legal	Subir <code>TERMS_VERSION</code> o <code>PRIVACY_POLICY_VERSION</code> .

Marco legal y operativo de Aether ERP

Estado al 3 de octubre de 2026. Este directorio reúne las políticas que rigen la operación de la plataforma y la lista de lo que falta para ofrecerla a clientes con el menor riesgo posible.

No es asesoría legal. Los textos describen lo que el sistema hace hoy y siguen prácticas habituales en Chile, pero **un abogado debe revisarlos antes de firmar el primer contrato**. Donde hay una cifra o un plazo legal que no está confirmado, el documento lo dice.

Documentos públicos (los ve el cliente o el público)

Documento	Dónde	Para qué
Términos de servicio	<code>/aether/terminos (src/app/aether/terminos/page.tsx)</code>	Contrato con la empresa cliente: responsabilidades, tope de responsabilidad, término, borrado de datos, IA, eventos, tribunales.
Política de privacidad de la plataforma	<code>/aether/privacidad</code>	Qué datos trata Aether como plataforma y cómo los protege.
Contrato de encargo de tratamiento	<code>/aether/encargado</code>	Obligaciones de Aether como encargado de los datos de cada cliente (Ley 21.719).
Subencargados	<code>/aether/subencargados</code>	Proveedores que tratan datos y dónde están.
Política de la postulación	<code>/politica-privacidad?certamen=...</code>	Datos de candidatas (incluye sensibles y menores).
Aviso de privacidad de formularios públicos	<code>/aviso-privacidad?flujo=...&t=...</code>	Entradas, votos, cuotas, portal del auspiciador y encuesta. Enlazado al pie de cada formulario.
Formulario de derechos	<code>/derechos/[token]</code>	Acceso, rectificación, supresión, oposición, portabilidad y bloqueo.

Aceptación registrada. Cada usuario acepta los términos y la política al activar su cuenta (casilla obligatoria en `/accept-invitation`). Se guarda `User.termsAcceptedAt` y `User.termsVersion`. Al cambiar los términos o la política de la plataforma, sube `TERMS_VERSION` en `src/lib/legal/constants.ts`. Al cambiar la política de la postulación, sube `PRIVACY_POLICY_VERSION` en `src/lib/privacy/constants.ts`.

Políticas internas (cómo opera Aether)

1. Seguridad de la información
2. Respuesta a incidentes y vulneraciones de datos
3. Conservación, respaldos y eliminación de datos
4. Continuidad operativa
5. Lista de lanzamiento legal y operativa: lo que tienes que hacer tú, en orden.

Complementan `docs/proteccion-datos.md` (estado de cumplimiento de la Ley 21.719 dentro del sistema) y `docs/security/cloudflare.md`.

Política de seguridad de la información

Alcance: la plataforma Aether ERP, su código, su infraestructura (Vercel, Neon, Cloudflare, R2) y las personas con acceso administrativo.

Dueño de la política: el representante legal de Aether. Se revisa cada 6 meses o tras un incidente.

1. Principios

- **Mínimo privilegio:** cada persona y cada servicio tiene solo el acceso que necesita.
- **Aislamiento por empresa:** toda consulta a la base filtra por `companyId`. Una empresa nunca ve datos de otra (CLAUDE.md, sección 2.3).
- **Defensa en profundidad:** ninguna barrera es la única (sesión + permisos + filtro de empresa + firewall de borde).
- **Nada sensible en texto plano:** contraseñas con `bcrypt` (costo 12); credenciales de integraciones, CAF, mensajes y TOTP cifrados con AES-256-GCM.

2. Accesos administrativos

Sistema	Regla
Vercel, Neon, Cloudflare, GitHub, proveedor de correo	Verificación en dos pasos obligatoria. Al menos dos personas de confianza con acceso de administrador, para no depender de una sola.
Superadmin de la plataforma	Solo el equipo de Aether. Cada acción queda en la auditoría.
Secretos (variables de entorno)	Solo en Vercel, marcados como <code>*sensitive*</code> . Nunca en el repositorio, en chats ni en correos. Se rotan si una persona con acceso deja el equipo o ante sospecha de filtración.
Base de datos de producción	No se usa desde computadores personales para desarrollo. Desarrollo y pruebas usan una rama de Neon separada.

Las llaves de cifrado no se cambian a la ligera. `TOTP_ENCRYPTION_KEY` hoy cifra también los CAF, credenciales de pasarelas e integraciones y la mensajería, porque las llaves específicas (`DTE_ENCRYPTION_KEY`, `PAYMENTS_ENCRYPTION_KEY`, etc.) no están definidas. Si se agrega o cambia una de ellas sin volver a cifrar lo existente, **esos datos quedan ilegibles**. Cualquier cambio de llave se hace con un script de recifrado probado antes en una rama de Neon.

3. Desarrollo seguro

- Toda Server Action empieza con `requireAuthWithPermission` y valida con `Zod`.
- Antes de desplegar: `npm run ci` (Prisma, tipos, lint y tests) en verde.
- Migraciones aditivas e idempotentes; el SQL se revisa antes de aplicarse.
- Dependencias: revisión mensual de avisos de seguridad (`npm audit`) y actualización de los paquetes con vulnerabilidades.
- Archivos de clientes: los sensibles (certificados médicos, contratos de candidatas) van al bucket **privado** de R2 y solo se leen por rutas autenticadas que auditan la descarga.

4. Protección en el borde

- Cloudflare delante de la aplicación: TLS Full (strict), WAF, límite de peticiones y Turnstile en login y formularios públicos (`docs/security/cloudflare.md`).
- Firewall de Vercel que bloquea el acceso directo a `*.vercel.app`.

5. Monitoreo

- Errores de producción a observabilidad (`captureException`) y, con `SENTRY_DSN`, a Sentry.
- Monitor externo de disponibilidad con aviso al celular.

- Revisión semanal de errores nuevos y mensual de accesos (usuarios inactivos, claves sobrantes).

6. Proveedores

Cada proveedor que trata datos figura en `src/lib/privacy/subprocessors.ts` (página `/aether/subencargados`). Se agrega **antes** de empezar a usarlo. Las claves de servicios que no se usan se eliminan de Vercel.

Plan de respuesta a incidentes y vulneraciones de datos

Objetivo: contener rápido, avisar a quien corresponde dentro de plazo y dejar constancia.

1. Qué es un incidente

- Acceso no autorizado a datos de un cliente (o sospecha fundada).
- Datos de una empresa visibles para otra.
- Filtración de un secreto (clave de API, llave de cifrado, credencial de base de datos).
- Pérdida o borrado no intencional de datos.
- Caída total del servicio por más de 1 hora en horario hábil.

2. Pasos

#	Acción	Responsable	Plazo
1	Contener: revocar el acceso o la clave comprometida, suspender la cuenta afectada, activar el modo *Under Attack* de Cloudflare si es un ataque.	Quien lo detecta + administrador	Inmediato
2	Registrar en una bitácora: hora de detección, qué se vio, qué se hizo.	Administrador	Durante el incidente
3	Evaluar alcance: qué empresas, qué datos, cuántas personas, si hay datos sensibles o de menores. Usar la auditoría y los registros de Vercel/Neon.	Administrador	Primeras 24 h
4	Avisar al cliente afectado (responsable de los datos) con lo que se sabe, aunque sea preliminar. El contrato de encargo obliga a Aether a avisarle sin dilación indebida.	Representante legal	Sin dilación, idealmente dentro de 24 h
5	Apoyar al cliente en su aviso a la Agencia de Protección de Datos Personales y a los titulares, cuando la ley lo exija. Desde el 1 de diciembre de 2026 rige la Ley 21.719; confirmar con el abogado el plazo y el contenido exactos de esos avisos.	Representante legal + cliente	Según la ley
6	Corregir la causa y verificar que no se repita (test, regla, cambio de configuración).	Desarrollo	Lo antes posible
7	Cerrar: informe breve al cliente y registro en Configuración → Protección de datos → Incidentes de seguridad.	Administrador	Al cerrar

3. Restauración de datos

- Errores recientes: restaurar desde Neon a una **rama nueva**, revisar y recién entonces copiar lo necesario. Nunca restaurar encima de producción sin revisar.
- La ventana de restauración depende del plan de Neon (hoy, en el plan gratuito, es de **6 horas**). Por eso conviene el plan Launch antes de tener clientes.

4. Contactos de emergencia (completar)

Rol	Nombre	Teléfono	Correo
Representante legal			
Administrador técnico 1			
Administrador técnico 2			
Abogado			
Soporte Vercel / Neon / Cloudflare	Panel de cada proveedor		

Política de conservación, respaldos y eliminación de datos

1. Roles

Cada empresa cliente es la **responsable** de sus datos y define cuánto tiempo los conserva. Aether, como encargado, ofrece las herramientas y aplica lo que dicen los términos y el contrato de encargo.

2. Plazos que aplica la plataforma

Dato	Plazo	Cómo se cumple
Postulaciones descartadas (candidatas)	12 meses por defecto (CANDIDATE_RETENTION_MONTHS)	Purga automática mensual (cron /api/candidates/purge-retention/cron).
Documentos tributarios, contables y de pago	El plazo legal tributario y contable; el cliente lo confirma con su contador	No se borran a pedido del titular. El buscador de datos de una persona lo advierte.
Datos de trabajadores y remuneraciones	El plazo legal laboral y previsional; el cliente lo confirma con su asesor	Ídem.
Sesiones	8 horas	Expiración de la cookie.
Auditoría	Mientras exista la cuenta del cliente	Necesaria para seguridad y para acreditar el cumplimiento.
Datos de un cliente que termina el servicio	30 días para exportar y luego eliminación dentro de 90 días	Términos de servicio, sección 10. Se hace desde el panel de superadmin.
Ramas de Neon de prueba	Se borran al terminar la prueba	Hoy existen copias de producción con datos reales en ramas preview/*: borrarlas.

Los plazos sugeridos del registro de actividades (src/lib/privacy/processing-activities.ts) son un punto de partida. Cada cliente debe ajustarlos.

3. Respaldos

Capa	Qué cubre	Frecuencia
Restauración puntual de Neon (PITR)	Toda la base, hasta la ventana del plan	Continua
Exportación completa por empresa (/api/backup/company)	Datos de una empresa en JSON, sin credenciales	Mensual, guardada fuera de la plataforma
Archivos en R2	Fotos, logos, contratos, certificados	Activar versionado o copia periódica del bucket

Prueba de restauración trimestral: restaurar a una rama nueva, abrir la aplicación contra ella y verificar los datos de una empresa. Anotar la fecha y el resultado.

4. Eliminación segura

- Se elimina con las funciones de la plataforma (platform-delete.service.ts, purgas) que respetan el filtro por empresa.
- Los respaldos de Neon expiran solos al pasar su ventana; no se conservan copias manuales de la base de producción en computadores personales.
- Pendiente:** al eliminar una empresa desde el superadmin se borran sus datos de la base, pero **no** sus archivos (fotos, contratos, certificados) en R2 o Vercel Blob. Hasta automatizarlo, borrarlos a mano en el panel de R2 buscando las carpetas que contienen el id de la empresa (por ejemplo candidates/<companyId>/), para cumplir el plazo de 90 días de los términos.

Plan de continuidad operativa

Qué hacer para que la plataforma siga funcionando ante fallas, y cómo volver a operar si algo se cae.

1. Dependencias críticas

Servicio	Si falla	Plan
Vercel (aplicación)	La plataforma no responde	Ver estado en el panel de Vercel. Si un despliegue lo causó: Instant Rollback a la versión anterior.
Neon (base de datos)	Errores al cargar cualquier pantalla	Ver estado de Neon. Si es un dato dañado: restaurar a rama nueva (ver respuesta a incidentes).
Cloudflare	El dominio no carga	Pasar el DNS a "solo DNS" (nube gris) para entrar directo a Vercel mientras dura la falla.
Correo (Brevo/Resend)	No llegan confirmaciones ni recuperación de contraseña	Con ambas claves gana Brevo y no hay cambio automático al otro. Si Brevo cae, quitar temporalmente BREVO_API_KEY en Vercel y volver a desplegar para que salga por Resend (requiere dominio verificado en Resend).
SII	No se puede consultar ni enviar	El ERP sigue emitiendo con folios y timbre; el envío lo hace el cliente cuando el SII vuelva.
Khipu	No se pueden pagar cuotas en línea	Las cuotas se registran a mano en tesorería.
Gemini / NVIDIA	Los asistentes no responden	El resto del ERP no depende de ellos.

2. Antes de cada despliegue

1. `npm run ci` en verde.
2. Revisar el SQL de cualquier migración nueva (aditiva e idempotente).
3. Probar en un despliegue de vista previa conectado a una rama de Neon, **no a producción**.
4. Desplegar fuera de horas de mayor uso y mirar los errores durante los 15 minutos siguientes.

3. Eventos en vivo (galas, votaciones)

- Semana previa: prueba de carga de la venta de entradas y de votos; subir el mínimo de cómputo de Neon esa semana.
- No desplegar cambios el día del evento.
- Tener una persona disponible durante el evento con acceso a Vercel, Neon y Cloudflare.

4. Personas

- Dos personas con acceso de administrador a cada proveedor, con verificación en dos pasos.
- Credenciales de recuperación (códigos de respaldo de 2FA) guardadas en un gestor de contraseñas compartido del equipo, no en una sola cabeza.